

Chapter # 01

Basic Security Terminologies

- **Threat Environment** → Types of attacker and attacks that company face
- **Security Goals** →
 - **Confidentiality** → No one can read sensitive information either it's on computer or it is travelling across a network.
 - **Integrity** → Attackers cannot change or destroy information either while it is on computer or travelling across network. If at least it changed or destroyed then the receiver can detect the change or restore destroyed data.
 - **Availability** → means people who are authorized to use are not prevented from doing so.
- **Compromises** → Incidents also called breaches
- **Countermeasures** → Tools used prevent attacks also called safeguard, protection, and control.
- **Types of countermeasures** →
 - Preventative
 - Detective
 - Corrective
- **Malware** → Generic name for any "evil software".
 - ↳ **viruses** → program that attach themselves to legitimate programs on the victim's machine. Spread through emails. Also by file transfer, instant messaging.
 - ↳ **worms** → do not attach to other programs → spread through network.
 - Spread through e-mail, instant messaging and file transfers.
 - Self replicating.
 - ↳ **Blended threat** → Attacks that combines multiple types of threats into one attack.
 - Multiple attack vectors → such as Trojan, virus, worm are used together.

Objective → To increase speed and effectiveness by exploiting various vulnerabilities simultaneously.

• Payload Threat → The part of an attack that is designed to cause harm
→ Single component such as piece of code or malicious script is the core of damage.

Objective → To perform a specific malicious action, such as stealing data, decrypting file or deleting files.

Trojan horses and Rootkits:-

(virus, worm)

• Non-mobile Malware → placed on user's pc through any attack or by hacker, and then the victim is attracted to download the program from a website or FTP site.

• Trojan Horse → replaces an existing ^{system} file taking its name.

↳ RATs → Remotely controls the victim's PC. (Remote Access Trojan)

↳ Downloaders → smaller Trojan horses that download larger Trojan horses after the downloader is installed.

↳ Spyware → Program that gather information about you, and give it to hacker or any adversary. It can attach with legitimate softwares, emails, popups etc. It can get your personal info, steal passwords.

↳ Rootkit → Take control of super user account (root, administrator) Hide itself from system detection and make it difficult to detect. ordinary program (antiviruses) find few rootkits.

• Mobile code → Executable code on a webpage, code is executed when the webpage is downloaded. Js, Microsoft Active-X control. Can do damage if computer has vulnerability.

• Social Engineering in Malware → 'Social Engineering is attempting to trick users into doing something that does against their security policies.

• Spam

• fishing

• Spear fishing (targeted or aimed user)

• Hoaxes

↓
unsolicited
bulk emails,
advertising
etc

↓
fake email pretend
to be from trusted
people/company.

↓
• Target the individual/company
• Use the original name, job-title, Alerts spread on email or company.
• Harder to detect

↓
fake or false warning
Alerts spread on email or
Social media.

• Forward this message to
10 people or your account
will be deleted

Employee & Ex-Employee → They know the internal system, also have permission to access the system. They also know how to avoid the detection. They are trusted one (Employee).

- ↳ Employee Sabotage
 - Destruction of hardware, software or data.
 - Plant time bomb or logic bomb on computer.

- ↳ Hacking
 - Hacking any resources without authorization or in excess of authorization.

- ↳ Financial Theft
 - Misappropriation of assets.
 - Theft of money.

- ↳ Theft of Intellectual Property (IP)
 - Copyright or patent (formally protected).
 - Trade secrets; plans, product formulation, business processes etc.

- ↳ Extortion
 - Demanding money or any other goods by threatening or blackmailing him/her to reveal their secret.

- Internet Abuse → Downloading the pirated software, music or videos which can lead to copyright violation.

- Carelessness → Loss of USB or drive that contain data/media of sensitive info.
 - Carelessness leads to the theft of such information.

- Other internal Attackers → Contract workers
 - Workers in contracting companies.

- Traditional Hackers → Motivated by thrill, validation of skills, sense of power.
 - Motivated to increase reputation among other hackers.
 - Often do damage as a byproduct.
 - Often engage in petty crimes.

Anatomy of Hacks:

- IP address → Scan to identify possible victims.

- Port scans → to learn which services are open on each potential victim host.

↳ Sequence

- Reconnaissance → Scanning for active devices and open ports.
- Enumeration → Gathering details about the services and vulnerability.
- Exploitation → Attempting to breach a system using known flaws.

IP spoofing → It involves creating packets with a forged source address making it appear as if the packet came from a trusted or different system.

- ↳ Packet crafting → The attackers manually constructs IP packets and replaces the source IP address with fake one.

↳ Sending packets → These spoofed packets are sent to the target systems.

↳ Deception → The target believes the packets are from a legitimate source and may respond or grant access.

→ Common use in attacks

- DDoS Attack used to flood a target with traffic from fake source
- Man in middle Helps intercept and manipulate communications.
- Session Hijacking Spoofed IP used to take over user's session
- Bypassing filters Tricks firewalls or access controls.

→ chain of Attack computers: Attacker attack through the chain of victim computers.

- Probe and Exploit packets contain the source IP address of the last computer in the chain.
- The final attack computer receives the replies and passes them to the attackers.
- Victim can trace back to few computers only.

→ DDoS & DoS (Denial of service & Distributed Denial of service)

Both work same like overwhelming the system and make it unavailable, DDoS uses multiple sources while DoS uses a single origin.

Feature	DDoS	DoS
Source	Single Device	Multiple Devices (botnet)
Complexity	Easier to detect	Harder to trace & mitigate
Impact	Localized disruption	Large scale, often global disruption
Detection	Simpler due to origin	Complex due to distributed sources
Cost to launch	Low	High due to botnet access

→ Script Kiddies attacker

- Expert hackers are characterized by strong technical skills and dogged persistence
- Expert attackers create hackers script to automate some of their work.
- Script are also available for writing viruses and other malicious software.
- Script kiddies use these script.
- They have less technical skills.
- Script kiddies are dangerous because of their large number.

Cryptography

→ Use of mathematical operations to protect messages travelling between parties or stored on computer.

→ Encryption → Information has to be concealed from unauthorized person (attacker) so if they accessed it should not be useful to them.

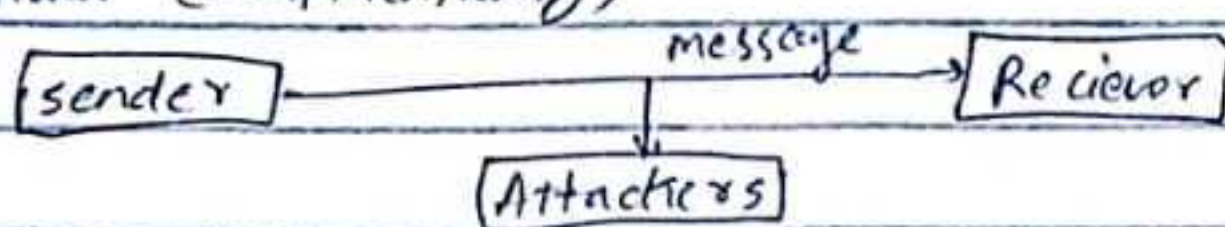
↳ Cryptography → Is the study of hiding info by encoding it to an unintelligible form using a secret key.

- The person will not be able to decode it until he have the key.

↳ Steganography → Is the study of hiding critical info with less important information.

Types of threat

→ passive attack (confidentiality)



→ Active threat (confidentiality & integrity)



→ Passive involve silently monitoring or stealing data without altering it, while active attacks involve directly modifying, disrupting, or damaging system or data.

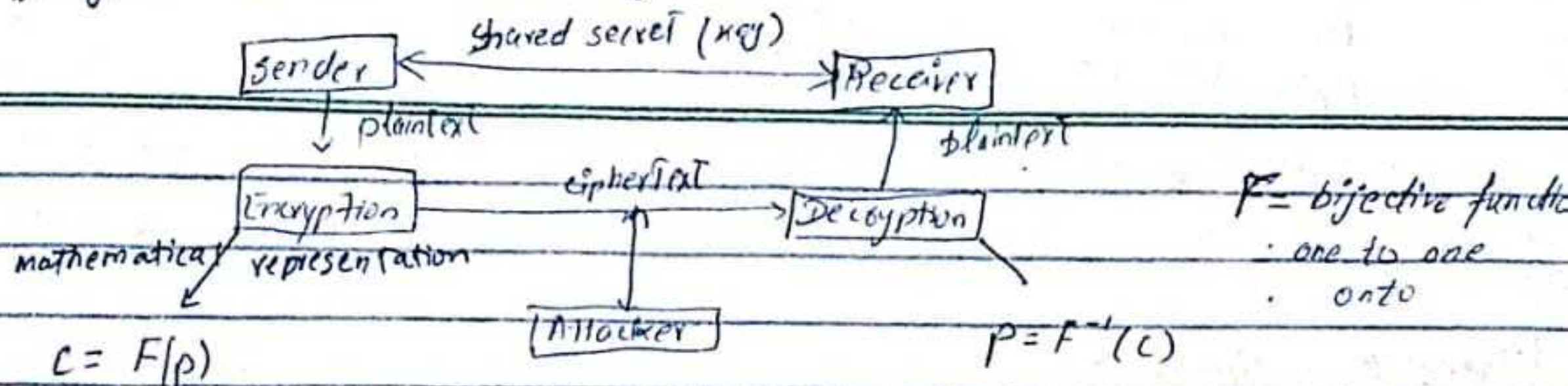
- A hacker uses a packet sniffer to monitor unencrypted Wi-Fi traffic and steal login credentials.

- An attacker injects malicious code into a website to redirect or steal data.

Cryptography: → mean "hiding words" "hidden writing" (in Greek).

- It is the study of encoding meaningful information (message or plain text) into a using secret transformation function cipher so nobody understand the Encoded message (the cipher text) unless they have knowledge of the cipher.

Encryption: The process of encoding plaintext into the ciphertext
 Decryption: The process of decoding ciphertext back to the original message (plaintext)



ROT-13 cipher Commonly used to hide the meaning of the messages on the Internet (Usenet or Email)

Each letter in the plaintext is substituted with ciphertext using following mapping

P = A B C D E F G H I J K L M N O P Q R S T U V W X Y Z
 F(P) = N O P Q R S T U V W X Y Z A B C D E F G H I J K L M

Example THIS IS A SECRET
 GUVF VF N FRPERG

It is an involution (ie self-inverse) means if encoded twice give the original (plaintext).

Caesar Cipher

Roman emperor Julius Caesar used to substitute each alphabet/letter with the letter that was 3 letter further along in the alphabet.

P: A B C D E F G H I J K L M N O P Q R S T U V W X Y Z
 F(P): D E F G H I J K L M N O P Q R S T U V W X Y Z A B C

Example HELLO
 KHOOR

The cipher used by Julius Caesar can be generalized to a function defined by parameter K = Number of letters we shift.

$$C = F_K(P) = P + K \pmod{26}$$

In Caesar Cipher $\rightarrow K = 3$

ROT-13 $\Rightarrow K = 13$

K = Key

• Simple Substitution or monoalphabetic substitution:- In this, each letter is replaced by a letter from a secret substitution alphabet.

P: A B C D E F G H I J K L M N O P Q R S T U V W X Y Z
F(p): Q W E R T Y U I O P A S D F G H J K L Z X C V B N M

- The substitution alphabet is the secret key shared between sender & receiver.
- It is stronger than Caesar cipher but still vulnerable to frequency analysis.

Transposition cipher where characters of the plaintext are rearranged rather than substitution.

↳ Railforce Cipher

P: TRANSPPOSITION CIPHER X

K = 5

T R A N S
P O S I T
I O N C I
P H E R X

Step 1 → Right in rows with 5 columns.

Step 2 → Read Column-wise

T P I P R O O H A S N E N I C R S T I X

Problem: The first and last letter remain unchanged, making it easier to guess the message boundaries.

- The key is the number that divides the total message length.

↳ Single Columnar TC → uses a word as key → instead of a number.

Key letter	S	E	C	R	E	T
Alphabetical order	5	2	1	4	3	6

C = 1st alphabetically

E = 2nd 3rd leftmost is 2, ... so on.

Step 2: Write plain text in row under the key

S	E	C	R	E	T
T	R	A	N	S	P
O	S	I	T	I	D
N	C	T	P	H	E
R					

Step 3: Now read column wise starting from the key letter alphabetically

Like ~~for~~ C = 1 → A I I → It's on 3rd position

E = 2 → R S C

E = 3 → S I H

R = 4 → N T P

S = 5 → T O N R

T = 6 → P O E

A I I R S C S I H N T P T O N R P O E = cipher text.

Why It's Better?

- Uses a word as key (more flexible than a no.)
- Harder to guess column order
- Can handle any message length
- Letters move around more unpredictably.

Cryptanalysis: Study of breaking ciphers (also called codebreaking or cracking, or reading the encrypted message without knowledge of the key.

Goal → • Decrypt a message • Recover a key

Types of attack depend on → The type of information available • Interaction with cipher

→ Cracking the Caesar Cipher

Encryption $\rightarrow C = p + K \pmod{26}$

Decryption $\hat{p} = c - K \pmod{26}$

- Only 25 useful keys (1-25) as $K=0$ does nothing so it's ignored
- To break it by exhaustive search, an attacker tries every key $K(1, 25)$ decrypt and inspects the output for readable English message.

Ciphertext KHOOB $\rightarrow$ try all 25 one of them will be HELLO

→ Cracking Simple Substitution

$26! = \sim 4 \times 10^{26}$ possible keys

- Difficult at computer even to calculate such number of keys
- so Exhaustive search (Brute force) is not practical.

→ So the frequency analysis breaks simple substitution cipher.

Steps: $\rightarrow$ Count how often each letter appears in the message

• Rank ciphertext letter by frequency.

• Guess that the most frequent cipher text letter maps to E, second to T, and third to A and so on.

• Apply those mappings to the ciphertext and look for readable words.

• Iterate $\rightarrow$ tweak mapping using common short words, digram (TH, HE, IN, AR) and context until plaintext emerges.

Features $\rightarrow$ • Digram Frequency EN, RE, ER, NT, TH

• Trigram Frequency THE, ING, THA, ENT

• Q followed only by U

• vowel other than E are rarely followed by other vowels.

Polyalphabetic cipher →

- The simple substitution cipher is weak b/c the attackers can exploit the fact
- The letter frequency distribution of the cipher text will match with the letter frequency of plain text.

~~These will generally fail~~

To enhance it the plain text letter is substituted with a different alphabet.

Vignere Vigenere cipher

- It is a polyalphabetic substitution cipher.
- A secret word or phrase representing the key is agreed by sender & receiver.

$$C_i = P_i + K_i \pmod{26} \quad \Rightarrow \text{where } i = \text{position / number (period)}$$

Cracking the Vignere Cipher or Repeated cipher

Step	Action	Purpose
1)	Find repeating letter pattern	Identify spots where some key repeated
2)	Measure distance b/w them (L.C.M)	Helps guess how often key repeats
3)	Find factors of distance	Possible key lengths (periods)
4)	Test those lengths	Confirm by decoding parts.

Example

GBW 4BSZTFNZX GBWHESZX

$$GBW \rightarrow 1 - 13 = 12$$

$$SZ \rightarrow 6 - 18 = 12$$

$$ZX \rightarrow 11 - 19 = 8$$

common factors - 2 or 4

so length might be 2 or 4

Index of coincidence

Picking two letters at random from a text and they turn out to be the same letter.

$$N = 1000$$

$$\text{Number of A's} = 72$$

n = total letter in text

n_a = number of A's

n_b = number of B's ~ so on

$$IC = \frac{\sum n_i (n_i - 1)}{n(n-1)}$$

$$\text{Eg } \frac{72}{1000} \times \frac{71}{999}$$

HELLO

$n = 5$

Letter	n_i	$n_i(n_i - 1)$
H	1	0
E	1	0
L	2	$2 \times 1 = 2$
O	1	0
.	1	0

$$I_C = \frac{n_i(n_i - 1)}{n(n - 1)} = \frac{2}{5(5 - 1)} = \frac{2}{20} = 0.1$$

[For English plain text]

$E = 12.7\%$

$T = 9.1\%$

$$I_C = \sum (f_i^2) \Rightarrow 0.127^2 + 0.091^2 + 0.082^2$$

Hence $I_C \approx 0.0667$ for English Text (any)

[For Random letter]

$$f_i = \frac{1}{26} = 0.03846$$

$$I_C = 26 \times (0.03846)^2 = 0.0385$$

Simple Substitution $\approx 0.066 - 0.07$

Poly alphabetic $\approx 0.038 - 0.066$

Polygraphic Cipher

Working on Group of letters instead of single letter

Product Cipher

Combining substitution and Transposition methods together.

Example $\rightarrow$ Playfair Cipher $\rightarrow$ works on pair of letters (digraphs) instead of single one

ADFGVX Cipher

$\hookrightarrow$ used by German in WWI

Step 1 $\rightarrow$ substitution (using table of symbols, A, B, C, D)

Step 2 $\rightarrow$ Transposition (rearranging the letters based on key)

Modern Cryptography

→ Started in the 70's

→ operates on binary (plaintext) data using a binary key to generate binary ciphertext.

Types → Block cipher

- Take a block of plaintext bits (eg 64 bit, 128 bit)
- Use a secret key and
- Convert that block into a block of ciphertext of the same size.

• It encrypt data in chunks rather than full bit or letter at a time.

• Block cipher has length / Block size of n bit $= |P| = |C| = 2^n$

• Key size $|K| = 2^k$

• Example block size = 4 bit then $2^4 = 16$ possible plaintext blocks and also 16 cipher text blocks.

Block size = 2 bit ($m=2$)

→ $2^2 = 4$ (00, 01, 10, 11)

Key size = 1 bit ($k=1$)

→ $2^1 = 2$ (00, 01)

Possible ciphertext $\Rightarrow 2^2 = 4$ (00, 01, 10, 11)

Confusion

(mixture of linear & non linear operations)

Confusion means making the relationship between:

→ plaintext, ciphertext, and key

• as complex and unpredictable as possible.

→ Changing even one bit of the key should cause a big, unpredictable change in the ciphertext.

→ Change is done using non-linear operations — like substitution boxes (S-boxes) or mathematical transformations that don't follow a single pattern.

Plain Text = A

Key = K

Ciphertext = C

If someone know A and C it will be harder for them to figure K easily.

Real World Example = AES (Advanced Encryption Standard)

• Confusion is provided by S-boxes → They substitute bits in a non-linear way, scrambling relationships.

2) Diffusion

- Every bit of plaintext should affect many bits of the ciphertext.
- One bit change will cause ciphertext to change completely.

→ using linear mixing operations → permutations, shifts, or mixing bits across blocks.

Feistel Cipher:

A common structure used in many block ciphers like DES.

- The data block is split into two halves: Left (L) and Right (R)
- Each round uses a round function (F) and a subkey (K)

Process

- Input block $M = (L, R)$

- Substitution function (σ):

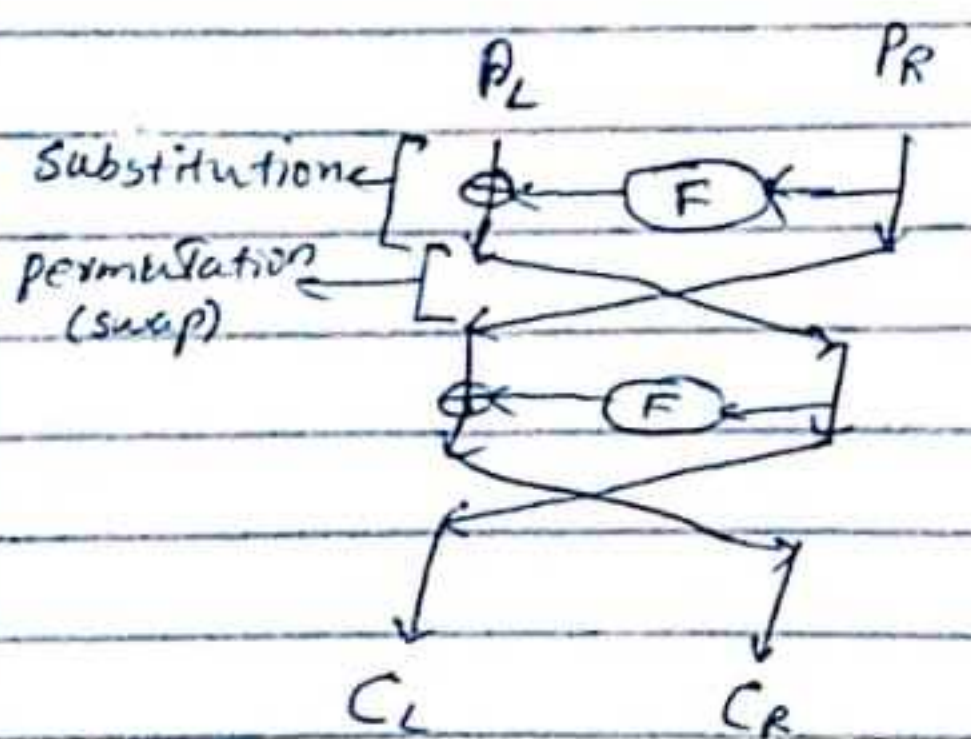
$$(\sigma((L, R), K) = (L \oplus F(R, K), R))$$

- Permutation function (π) (swap)

$$\pi((L, R)) = (R, L)$$

- Round function (ρ) = $\pi(\sigma((L, R), K))$

first apply substitution and then permutation



P_L & P_R = Plaintext

C_L & C_R = Ciphertext

1511

Note that at end permutation no occurs. This is to ensure that the Feistel cipher is an involution i.e. we don't need to design a separate cipher structure for decryption.

we use the same cipher structure and cipher function except the (subkey) round key are applied in reverse order